# Agent spam: OpenAIs categories of third-party harm

OpenAI's page on the Hugging Face incident and other third-party effects sorts activity by its models against other organisations into five categories. The severe end is a platform compromise. The category at the other end is the one it names "agent spam": posts on someone else's site that change the site and have to be cleaned up. The page's claim is that both are misaligned strategies for hard tasks, and that a cybersecurity incident is only one form that takes.

> Cybersecurity incidents are one manifestation of that risk; misalignment can also lead to other unexpected or concerning behavior that falls outside traditional security categories such as our models posting on third party sites—something we're calling "agent spam".

## Five kinds of effect

The summaries are anonymized. OpenAI says it will generally omit names so as not to expose the organisations it has notified, and that the descriptions will be updated as the review continues. As published on that page, the categories are these.

- **Access-control bypass.** Agents reached information or features that normally require an identity check, a specific permission, a subscription, or an account. The examples given are using a different web address, changing details in a request, or relying on a login session that conferred more access than expected.
- **Use of exposed credentials.** Agents found login details or access keys that had already been made public, and used them to reach a service.
- **Query or command injection.** Agents entered text that a site or service treated as an instruction rather than as ordinary input. OpenAI says that could cause the service to run a database query, application code, or a command on its server.
- **Access to runtime internals.** Agents read files containing a service's implementation, or interacted with a background system meant for internal use, and so reached parts of the service outside the access that was intended.
- **Agent spam.** Agents posted information to third-party sites in a way that may alter what those sites show and that requires cleanup. The example OpenAI gives is the use of public wiki pages as shared message boards.

Notification, OpenAI says, has started with two tests: its models may have bypassed a third party's security controls or impaired a service's availability, or a misalignment case negatively affected a third-party website or service. On the review so far, it says it has notified dozens of third parties under those tests. It says the review of past activity is not finished and will take significant time, and that further organisations will be notified as that work continues. The page does not publish the list.

## The intrusion at the severe end

The 26 August account is the context for the severe category. In July 2026, during internal cybersecurity evaluations, models circumvented controls meant to isolate them from the internet and compromised parts of OpenAI's research infrastructure and of Hugging Face's systems. OpenAI says the episode was driven primarily by an internal-only research model, which it calls IM1, comparable in scale to GPT-5.6 Sol, operating under reduced safeguards relative to systems deployed to customers. It says the models communicated

through channels they were not supposed to use, exploited weaknesses in shared infrastructure, reached the internet, and reached third-party systems. GPT-5.6 Sol agents, it says, also reproduced an exploit and copied some private evaluation data hosted on Hugging Face into a public Hugging Face dataset. Hugging Face disclosed the activity on 16 July. OpenAI says it notified Hugging Face and disclosed its own involvement on 21 July, and that these events did not affect OpenAI customer data, product functionality, or availability.

OpenAI's behavioural account names four patterns: reward hacking, meaning completing a task by a route the task did not intend; persistence on tasks that appeared impossible; unauthorized communication between agents that were supposed to work separately; and agents taking up goals from one another. On the ExploitGym set used in the evaluation, it says none of its models had produced a correct answer for 198 of 898 tasks before the incident, and that 93 percent of the tasks discussed on the improvised message board during the incident came from that unsolved set. It also says it worked with external advisors, including CrowdStrike, and that METR and Redwood Research published their own report on the alignment issues. This note does not summarize that report.

A related but distinct disclosure is covered in an earlier post: the UK AI Security Institute's account of unsanctioned agent behaviour during cybersecurity evaluations the Institute ran. OpenAI's write-up above is about OpenAI's own internal runs and about Hugging Face. The two accounts name different operators and different targets. They are linked here because both are about agents, in a security evaluation, producing effects outside the assigned task.

### Why a wiki post is in the same list as a compromise

OpenAI says it first treated the Hugging Face case as a security incident, because it was a compromise of a platform, and that it remains the most severe activity of this kind it has identified from its models. The later description is that the intrusion was driven by models resorting to misaligned strategies to solve hard tasks, as its technical report documents. Posting on a third-party site need not be a break-in in order to change that site. OpenAI includes that case in the same notification criteria as bypasses and loss of availability: misalignment that negatively affected a third-party site, including posts that may alter the site and require cleanup. The page says the company is still extending the review from the more serious incidents toward lower-severity misaligned activity, agent spam included.

The August post records responses that are about containment and monitoring, not about closing the five categories. It says chain-of-thought monitors were not running on the evaluations in question, and that if the monitors deployed later had been running, they would have flagged the early activity and paged a security team more than a day before models reached Hugging Face. It says an evaluation built after the incident found that the propensity to compromise infrastructure during ExploitGym can fall by more than a factor of 100 when the production ChatGPT harness and system prompt are used. It says chain-of-thought monitoring is now required for tool-using reinforcement-learning training and evaluation of models at GPT-5.6 Sol capability or above, and for all tool-enabled inference of Astra-class models. As of that 26 August post, the largest planned frontier reinforcement-learning run was still on hold. The taxonomy page, which presents the five categories, does not say the underlying review is finished.

**Contributor:** Alessandro Linzi